

PRACTICE PROJECT — FICTIONAL SCENARIO

HIPAA Security Rule

Gap Analysis and Risk Assessment

Northwind Family Health, LLC — a clinic I invented to work through the assessment

Project type	Self-directed learning exercise
Control set	45 CFR Part 164 Subpart C — all 65 standards and implementation specifications
Risk method	NIST SP 800-30 Rev. 1
Guidance used	NIST SP 800-66 Rev. 2; HHS SRA Tool v3.6
Companion file	02-hipaa-gap-analysis.xlsx — asset inventory, 65-control gap analysis, risk register, POA&M

Northwind Family Health does not exist. I made up the clinic, its systems, and its problems so I'd have a concrete environment to assess. The regulation, the control set, the citations, and the risk methodology are real.

1. What I did

The HIPAA Security Rule requires every covered entity to conduct “an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability” of its electronic protected health information — 45 CFR § 164.308(a)(1)(ii)(A). It's a required implementation specification, it has to be kept current, and its absence is the deficiency HHS Office for Civil Rights cites most often against small practices.

I wanted to know what producing one actually involves, so I invented a three-site primary care practice with 85 staff and 118,000 patient records, gave it a realistic set of systems and a realistic set of problems, and assessed all 65 standards and implementation specifications against it.

I read the control text from eCFR rather than a framework summary, used NIST SP 800-66 Rev. 2 to work out what each control means in practice, and scored risk with NIST SP 800-30 Rev. 1. For each control I also wrote down what evidence you'd need in order to verify it — a document to inspect, a configuration to check, a report to sample. That column taught me the most.

The main thing I found

The clinic has bought good software and hasn't built any of the practices that software depends on. Only three of 65 controls fully pass, and all three are ones where a vendor supplies the safeguard automatically — the EHR's immutable audit trail, TLS on system interfaces, and cloud backup integrity checking. Every control that requires the clinic itself to do something on a recurring schedule — review access logs, test a restore, train staff, revoke a departing employee's account, look at a business associate agreement — is missing or partial.

That's a coherent failure mode rather than a random one, and in a practice where security is nobody's actual job it's the one you'd expect. It's also mostly fixable with time rather than money: eleven of the twenty remediation items need no new spending, and the two most severe technical risks are addressed for about \$6,300.

Where the clinic stands

Result	Count	% of 65	What it means
Implemented	3	5%	Vendor-supplied safeguards working
Partially Implemented	24	37%	Control exists but has scope or documentation problems
Not Implemented	32	49%	Absent, or an addressable spec with no documented decision
Alternative Measure	1	2%	Documented equivalent, as § 164.306(d)(3)(ii)(B) allows
Not Applicable	5	8%	Clearinghouse and group health plan provisions

On that 32. Ten of them are addressable implementation specifications. Addressable doesn't mean optional — § 164.306(d)(3) requires you to implement the spec, implement a documented equivalent, or write down why it isn't reasonable for you. The clinic does none of the three for those ten, which is why I rated them as failures rather than as choices. Several would probably be defensible as documented decisions. None is defensible as a silence.

Risk profile

Tier	Now	After fixes	Risks
Critical	3	0	R-01 no MFA · R-02 no risk analysis · R-05 unpatched server, backups on the production network
High	9	1	R-03, R-04, R-06, R-07, R-08, R-09, R-11, R-12, R-13
Moderate	3	9	R-10, R-14, R-15
Low	0	5	—

One risk stays High after remediation: R-13, staff susceptibility to phishing. Training and simulation reduce it a lot but don't eliminate it, and a register that showed every risk dropping to Low after a year of work wouldn't be believable.

2. The five findings that matter most

All fifteen risks are in the spreadsheet. These are the ones I'd put in front of the practice owner first, in order of score.

R-01 — Remote access to the whole patient record needs only a password

Risk tier	Critical	Score	25 (Likelihood 5 × Impact 5)
Citation	45 CFR § 164.312(d); § 164.312(a)(1)		

What's wrong. The EHR is reachable from the public internet with a username and password alone — no multi-factor authentication, no conditional access, no IP restriction. Twelve providers connect from home routinely. The two domain administrator accounts are single-factor as well.

Why it matters. Stolen credentials are the leading way healthcare breaches start, and a clinic's credentials are one successful phishing email away — which R-13 makes likely, since 34 staff have never had security training. With no login monitoring and no log review (R-11), an attacker who logs in successfully looks exactly like a provider working from home. This one control failure is what turns a routine phishing incident into a 118,000-record breach.

Fix. Turn on the EHR's built-in MFA for all 91 accounts and enforce it on every remote session. It's already included in the licence — this costs about 24 hours of work and no money. Add conditional access for the four admin roles. (PM-01)

R-02 — No risk analysis has ever been done

Risk tier	Critical	Score	20 (Likelihood 5 × Impact 4)
Citation	45 CFR § 164.308(a)(1)(ii)(A), (B); § 164.308(a)(8); § 164.316		

What's wrong. There's no risk analysis, no risk management process, no periodic evaluation, and no security governance of any kind. The only compliance document is a purchased template binder from 2014 with the blanks unfilled. It predates the EHR, the move to cloud email, remote clinical work, and two of the three clinics. No staff member can find any security policy.

Why it matters. This finding is different from the others. They describe specific exposures; this one describes the missing mechanism by which the clinic would ever find them. It also has the sharpest legal

consequence — HIPAA penalties are tiered by culpability, and the top tier is willful neglect. A breach at a practice that had done a risk analysis, found the gap, and was working a documented plan is a very different regulatory situation from a breach at a practice that never looked.

Fix. Adopt this assessment as the baseline, with the owner signing it. Set an annual review and a quarterly security review meeting. Replace the 2014 binder with a real policy set. (PM-02, PM-18)

R-05 — Unpatched file server, and backups sitting on the production network

Risk tier	Critical	Score	20 (Likelihood 4 × Impact 5)
Citation	45 CFR § 164.308(a)(5)(ii)(B); § 164.308(a)(7)(i)		

What's wrong. The file server hasn't been patched since August 2025. Endpoint protection is Defender at defaults with no central console and no alerting. Worse, the backup NAS is reachable over SMB from the same network segment as the workstations using a shared local credential, and the cloud copies aren't immutable.

Why it matters. The backup setup is what makes this critical rather than just serious. Ransomware that reaches a workstation reaches the NAS with the same credential, and can delete the cloud copies rather than just encrypt them. The clinic's recovery position in that scenario isn't degraded, it's gone — for a practice that can't see patients without the EHR. And a ransomware event affecting ePHI is presumed to be a reportable breach under § 164.402 unless you can show a low probability of compromise, which the clinic currently has no ability to assess.

Fix. Deploy managed EDR across the estate (~\$4,300/yr) and start a monthly patch cycle. Separately and just as urgently, move the NAS to an isolated VLAN with its own credential and turn on cloud object-lock immutability. (PM-03, PM-04)

R-13 — Security training last happened in 2019

Risk tier	High	Score	16 (Likelihood 4 × Impact 4)
Citation	45 CFR § 164.308(a)(5)(i), (ii)(A), (ii)(C)		

What's wrong. One onboarding module in 2019 is the entire training record. The 34 people hired since have had none. No annual refresher, no phishing simulation, no security reminders. New-hire orientation covers HIPAA privacy with no security content, and most staff wouldn't know how to report a suspected incident.

Why it matters. Training is a standard, not an addressable spec — § 164.308(a)(5)(i) requires a programme for the whole workforce including management, and there isn't one. Beyond compliance, it's the enabler for both critical technical risks: R-01 needs an attacker to get a credential and R-05 needs a payload to run, and phishing is the ordinary route to both. Any control that depends on someone noticing something wrong currently has nothing behind it.

Fix. Annual role-based training with tracked completion, monthly phishing simulations with follow-up for anyone who clicks, quarterly reminders. About \$2,400/yr. Keep the completion records — they're the § 164.316(b) evidence. (PM-08)

R-03 — Three of five business associates have no valid agreement

Risk tier	High	Score	16 (Likelihood 4 × Impact 4)
-----------	------	-------	------------------------------

Citation	45 CFR § 164.308(b)(1); § 164.314(a)(1), (a)(2)(i)
-----------------	--

What's wrong. The after-hours answering service has been taking patient names, callback numbers, and symptoms since 2019 with no business associate agreement at all. The billing vendor's agreement is from 2016, predates the 2013 Omnibus Rule, and has no subcontractor flow-down or incident reporting. The EHR agreement has incident reporting but no deadline. There's no contract register — two of the agreements had to be found by asking the vendors.

Why it matters. A missing or deficient BAA is a violation on its own, whether or not any ePHI is ever mishandled, and OCR has penalised entities on that basis alone. The EHR gap has a practical edge too: with no contractual notification deadline, the clinic can't guarantee its own 60-day obligation to patients under § 164.404, because that clock runs from its own discovery. This is the cheapest category of finding to fix and the hardest to explain being caught with.

Fix. Get an agreement signed with the answering service before mid-May or suspend the service. Repaper the billing vendor on a current template. Get a 15-day notification addendum from the EHR vendor. Start a BAA register with annual review. About \$1,800 in legal review. (PM-05)

3. What to fix, in what order

Twenty items are tracked in the POA&M tab with owners, costs, and dates. Sequenced into three waves — the first wave is the set whose absence would most aggravate an enforcement outcome, and several are prerequisites for what follows.

Wave 1 — by mid-June

Item	Action	Owner	Cost
PM-01	Turn on MFA for all 91 EHR accounts	IT Lead	\$0 (licensed)
PM-02	Adopt the risk analysis; set annual review and quarterly meeting	Practice Admin	\$0
PM-05	Answering service BAA; re-paper billing vendor	Practice Admin	~\$1,800
PM-06	Disable 11 orphaned accounts; add revocation to the HR exit checklist	IT Lead / HR	\$0
PM-03	Deploy EDR; bring the file server's patching current	IT Lead	~\$6,300
PM-13	Change the fax appliance's default admin password	IT Lead	\$0

Wave 2 — by end of August

This wave is where the recurring practices get built, which is the report's whole theme.

Item	Action	Owner	Cost
PM-04	Segment the backup NAS; enable cloud object-lock	IT Lead	\$0
PM-08	Annual training programme; monthly phishing simulation	Practice Admin / HR	~\$2,400/yr
PM-09	Set RTO/RPO; run and document the first restore test	IT Lead	\$0
PM-10	Encrypt the 12 remaining devices; enforce compliance in Intune	IT Lead	\$0 (licensed)
PM-11	Monthly log review, signed by the Security Official	Practice Admin	\$0
PM-07	Quarterly access reviews with owner sign-off	IT Lead	\$0
PM-12	Email encryption and DLP for outbound ePHI	IT Lead	\$0 (licensed)
PM-15	Privacy filters; shorter automatic logoff timers	Practice Admin / IT	~\$900

Wave 3 — by end of November

Item	Action	Owner	Cost
PM-18	Publish the full policy set; staff attestation	Practice Admin	\$0
PM-14	Lock and ventilate the IT closet; rotate door codes; visitor logs	Practice Admin	~\$2,800
PM-19	Sanitize and dispose of stored media per NIST SP 800-88	IT Lead	~\$650
PM-13	Fax retention policy, purge, and encryption or migration	IT Lead	~\$1,100/yr
PM-17	Rotate the imaging SFTP keys; encrypt the landing directory	IT Lead	\$0
PM-16	Quarterly vulnerability scanning and an annual penetration test	IT Lead	~\$19,500/yr

Item	Action	Owner	Cost
PM-20	Adopt the asset inventory; assign custodians	IT Lead / Practice Admin	\$0

Cost

Category	Year one	Recurring
Already licensed (MFA, encryption, DLP, immutability)	\$0	\$0
Endpoint detection and response	~\$6,300	~\$4,300
Security awareness and phishing simulation	~\$2,400	~\$2,400
Legal review of business associate agreements	~\$1,800	~\$500
Physical security and media disposal	~\$4,350	~\$200
Encrypted fax service	~\$1,100	~\$1,100
Vulnerability scanning and penetration testing	~\$19,500	~\$19,500
Total	~\$35,450	~\$28,000

More than half the total is the optional scanning and penetration testing in PM-16. Without it the programme is about \$16,000 in year one, and the two Critical technical risks are covered for roughly \$6,300.

4. The proposed rule change

Status as of August 2026: HHS published a notice of proposed rulemaking on 6 January 2025 (90 Fed. Reg. 898) proposing the first big Security Rule overhaul since 2013. Comments closed in March 2025 with over 4,000 received. **It is not final.** HHS has moved it to the long-term actions agenda and now estimates July 2027 for final action. If it's finalized roughly as proposed, entities would get 240 days to comply.

Nothing here is enforceable yet and no finding in this report depends on it. I included it because several proposed requirements line up with remediation the clinic is doing anyway, and sequencing with the proposal in view costs nothing.

Proposed requirement	Where the clinic stands	Ready?	Item
Addressable specs become required — the flexibility goes away	Ten addressable specs are unimplemented with no documented decision. These become plain failures	No	PM-18
MFA for ePHI access	None anywhere. Already the top finding under the current § 164.312(d)	Underway	PM-01
Encryption of ePHI at rest and in transit	12 unencrypted devices, unencrypted backup NAS, ~61,000 unencrypted faxes, plaintext email	Underway	PM-10, 12, 13
Asset inventory and network map, reviewed annually	No inventory existed. The one built here covers it; no network map yet	Partial	PM-20

Proposed requirement	Where the clinic stands	Ready?	Item
Vulnerability scans every 6 months, pen test annually	Neither has ever happened. Already a gap under the § 164.308(a)(8) evaluation standard	No	PM-16
Internal compliance audit every 12 months	No evaluation of any kind has been done. This assessment is the first	Underway	PM-02
Network segmentation	Flat network; the backup NAS shares a segment with production, which is what makes R-05 critical	Underway	PM-04

What I'd take from it. Where an addressable spec could be met either by implementing it or by documenting a decision not to, implement it — the flexibility may not survive the final rule and the effort is comparable. Add a network diagram to PM-20 while building the inventory. And don't defer anything on the grounds that the rule might change: it isn't final, 4,000 comments may move it, and every item in the plan is justified by the rule as it stands.

5. Limits of this exercise

Worth being straight about what this project is and isn't.

- It's a scenario I invented. There was no real environment, no real evidence, and nobody to interview. The evidence column describes what you'd need to collect, not what I collected.
- No technical testing. I couldn't scan or pen test a clinic that doesn't exist, so those appear as recommendations rather than results.
- The scenario is one I designed, so the findings are ones I planted. The exercise was in working out which controls each problem breaches, how to cite it, how to score it, and how to explain it — not in discovering the problems.
- A real assessment would have to deal with evidence that's incomplete, contradictory, or contested by the people who provided it. I skipped all of that, and I suspect it's most of the actual difficulty.

What I'd do differently next time

- Write the evidence column first. Deciding what would prove a control works clarified the control's meaning far better than reading the regulation again did.
- Score risk before writing findings. My first pass rated almost everything High, and I only fixed it by going back and pinning down what Likelihood 3 versus 4 actually means.
- Try the same thing against a different framework — probably SOC 2 or PCI DSS — to see how much of what I learned transfers and how much was HIPAA-specific.

Sources

- 45 CFR Part 164, Subpart C — Security Standards for the Protection of ePHI (eCFR)
- 45 CFR Part 164, Subpart D — Breach Notification (eCFR)
- NIST SP 800-66 Rev. 2 (February 2024) — Implementing the HIPAA Security Rule
- NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments
- NIST SP 800-53 Rev. 5 — control crosswalk; NIST SP 800-63B — authentication; NIST SP 800-88 Rev. 1 — media sanitization

- HHS / ASTP Security Risk Assessment (SRA) Tool v3.6 (September 2025)
- HHS Notice of Proposed Rulemaking, 90 Fed. Reg. 898 (6 January 2025) — proposed, not final
- HHS OCR breach portal — used to pick realistic threat scenarios